

Intro to Cybersecurity

Learning Sources

- "Application Security Engineering - Study Plan"

Application Security

Intro to AppSec

-The discipline of finding, fixing, and preventing security vulnerabilities in software. How can this software be broken?

-All software has an attack surface, covering input, auth flows, bad dependencies, etc. AppSec Eng map this surface, probe it for weaknesses, and work w/ dev teams to have the weaknesses corrected.

-AppSec spans the full SDLC. Secure code review during dev, static analysis during testing, dynamic analysis during application execution, and manual pen testing of both static and dynamic.

-OWASP Top 10 highlights most critical risks, such as SQL injection and XSS. Each risk is a vulnerability class an AppSec eng knows well as a foundational understanding of how systems fail.

Why AppSec Eng

-My past 5 years in building web applications give me a leg up, as I already know the languages, components, and systems that AppSec Eng work with, from building them myself.

-I understand not just what vulnerabilities exist, but why dev may write them to begin with.

-Pretty much all main tech I used at my last job, from FastAPI (REST framework), to Python, to Docker, to writing tests is relevant for the switch to cyb.

-No endless leetcode cramming, dead dev job market, and convoluted and disorganized interview formats. Still practical exams during interviews, but not like in dev, which has just become ridiculous.

Why Now

-It is currently July 2026. Web dev layoffs have been running strong for 3+ years now. There are few jobs and what jobs there are have hundreds of applicants each.

-Cybersecurity workers, in contrast, are in high demand, and cyb as a whole (sans very basic positions) has been more resistant to AI layoffs, with AppSec postings up 12% from the prior year.

-USA breach costs reached a record \$10.22 million in 2025 and the IBM study that revealed this showed that nearly 2/3 of orgs they studied are still recovering from breaches.

-More than 45% of data breaches in 2024 involved at least one app-layer vulnerability. Over 60% of Fortune 500 companies now integrate AppSec testing into their SDLC.

-There is a talent shortage for AppSec and demand is growing faster than it can be filled by workers. The AppSec testing market is growing 26.7% annually.

Target Role: Application Security Engineer

-AppSec Eng share the same domain as Soft Eng (web). HTTP, APIs, auth flows, browser sec models, DB queries, etc. Instead of building the software, AppSec scans it for sec vulnerabilities.

-How can I break it like an attacker might, versus how can I build it.

-Daily responsibilities include:

- Secure Code Review - reading code to find vulnerabilities
- Pen Testing / DAST - Running Burp Suite on a staging env and testing HTTP requests
- SAST - Running and maintaining SAST tooling in CI/CD
- Threat Modeling - of new systems and features
- Vulnerability Reporting & Remediation Tracking - involvement when vulnerabilities found
- Sec Training & Dev Education - working w/ dev teams to help improve dev side cyb practices
- Dependency & Supply Chain Sec - SCA scanning, CVE monitoring, patch prioritization

Compensation

-Entry roles pulling in \$90k to \$130k, mid roles \$130k to \$180k, senior \$170k to \$240k

Job Market

-Good Philly opportunities via local health tech, financial services, enterprise, and legal tech companies such as Penn Medicine, Vanguard, and Comcast

-A huge number of cybersecurity jobs also allow remote flexibility, meaning the DC and NYC job markets open up, plus further away remote options

Concerns

-AI replacement - While this is a risk, the high-level nature of AppSec makes replacement unlikely in the immediate future

-Poor entry-level hiring - While Junior Sec Analysts may be getting hired less, AppSec jobs are not as threatened, plus my large portfolio from completing this study plan gives me an advantage.

-The cert trap - This plan is heavily focused on hands-on and project work, not just certs, so the cert trap is avoided. Real knowledge and skills, not just note cards memorized.

-Philly job market - Philly is not a tech hub, but AppSec remote jobs are very common. Network locally, apply nationally.

-Red team scope creep - AppSec does involve app & net level pen testing, but the plan makes sure to only cover it as much as I need for AppSec and not go full red team level in what it teaches.

Study Plan

Overview

-Plan will take 7-9 months @ 21 hours studying per week. It is limited in hours due to needing to do part-time gig work during this time, to support a simple lifestyle during career transition.

-The plan is centered around a lot of lab work and practical hands-on work via PortSwigger, as well as gaining BSCP and Sec+ certs. It also covers a phase for interview prep.

Study Phases

0	I	II	III	IV	V	VI	VII	VIII	IX
Pre-Study	AppSec Intro	Web & Network	Core Vulns	Testing & Tooling	Cloud Security	Code Review	Sec+ Cert	Interview Prep	First Days
Wks 1-3	Wks 4-5	Mo 1.25-2.25	Mo 2.25-4.0	Mo 4.0-6.25	Mo 6.25-6.75	Mo 6.75-7.5	Mo 7.5-8.5	Mo 8.5-9.25	Mo 9.25+

-Phase 0: Pre-Study - Refresh of existing web dev topics, completing FastAPI official docs, and building a new FastAPI app along w/ docs

-Phase I: AppSec Intro - A fun and short dip into offense and a taste of the attacker mindset via books, labs, and write-ups

-Phase II: Web & Network - Material on web and network that may not be known from web dev. An alternative to going full Net+.

-Phase III: Core Vulnerability Classes - A lot of OWASP here. The main classes used by attackers w/ hands-on practice via PortSwigger labs and write-ups.

-Phase IV: Security Testing & Tooling - BURP Suite mastery, along w/ in-depth SAST, DAST, SCA, and secrets scanning. Focus is PortSwigger and labs. BSCP exam prep + cert.

-Phase V: Cloud Sec - The basics of AWS Cloud Security, including shared responsibility, IAM, and common misconfigs via flaws.cloud, flaws2.cloud, and AWS docs.

-Phase VI: Secure Code Review & Threat Modeling - How to do manual review and threat modeling via OWASP Code Review Guide and other readings w/ documented code review and threat model project

-Phase VII: Sec+ Cert - Study for and get the Sec+ cert via books, note cards, and practice exams.

-Phase VIII: Interview Prep & Interviewing - Practicing for interviews, via labs covering all the main OWASP classes, plus a ton of note card review and practicing behavioral / past job answers.

-Phase IX: First days on the job and tips on how to make the most of my first few weeks and months at the new job

Study Methodology

-Mentorship - Get an AppSec mentor via MentorCruise. Have them review my study plan. Work with them throughout the plan to ensure I am heading in the right direction and that the work I am producing is good and accurate. Run mock interviews with them.

-Note Taking & Note Cards - Take notes on everything I learn, while learning it. These notes then exist forever, for later review and reading. Convert the notes into 3"x5" note cards for memorization.

-Local & Regional Events - Attend a lot of them. It will help me feel like part of the industry again and motivate me in my studies. As I get to know people via repeat interactions, it will build a network I can utilize during job application time. I can talk about my work, once I get further into it.

-Study Portfolio - Documented offensive work including vulnerability write-ups, lab solutions, CTF walkthroughs, threat modeling docs, and other work produced through plan. It all gets committed to GitHub, even my notes. Start publishing my work on LinkedIn once I get into Phase III, where the heavy OWASP work begins and study moves past just filling in gaps from dev.